

Security+ 3.3 · Data Types & Classifications

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 3.3 — Data Types & Classifications**
(5:54) · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Classificar o dado: PUBLIC (nada perde); INTERNAL (apenas dentro); CONFIDENTIAL (estratégia, PII — fuga = dano grave); RESTRICTED (trade secret — fuga=catastrófico). A classificação DETERMINA o controle. PHI=dado de saúde; PCI-DSS=cartão.

Highlights que a prova cobra

- Classificação determina QUAL proteção cada dado recebe
- PHI = saúde; PCI-DSS = cartão; PII = dados pessoais

Dicas de prova & Cenários Típicos

- 'least restrictive classification'=public; 'most restrictive'=restricted

Cenário clássico de exame: 'dado de cliente com nome, endereço, CPF'=PII — classificação confidential.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 3.3 — Data Types & Classifications)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **DLP:** Data Loss Prevention: Ferramenta técnica que monitora, detecta e bloqueia a exfiltração não autorizada de dados sensíveis (CPF, cartões, propriedade intelectual) em repouso, trânsito ou uso.
- **MFA:** Multi-Factor Authentication: Autenticação multifator exigindo dois ou mais fatores distintos das categorias: algo que você sabe, algo que você tem, algo que você é, algo que você faz ou algum lugar onde você está.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. No modelo de RESPONSABILIDADE COMPARTILHADA, quem cuida da segurança FÍSICA do datacenter?

- A)** O cliente
- B)** O provedor de nuvem
- C)** Os dois igualmente
- D)** Um auditor externo

2. Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:

- A) DLP (Data Loss Prevention)**
- B) SSO**
- C) MFA**
- D) VPN**

3. Cenário corporativo (Data Types & Classifications): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.3), um analista avalia o seguinte requisito técnico: 'Classificação determina QUAL proteção cada dado recebe'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas**
- D) Implementar a solução correspondente: Classificação determina QUAL proteção cada dado recebe...**

4. Cenário corporativo (Data Types & Classifications): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.3), um analista avalia o seguinte requisito técnico: 'PHI = saúde; PCI-DSS = cartão; PII = dados pessoais'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas**
- D) Implementar a solução correspondente: PHI = saúde; PCI-DSS = cartão; PII = dados pessoais...**

5. Cenário corporativo (Data Types & Classifications): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.3), um analista avalia o seguinte requisito técnico: "least restrictive classification'=public; 'most restrictive'=restricted'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'least restrictive classification'=public; 'most restrictive'=restricted...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Data Types & Classifications): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.3), um analista avalia o seguinte requisito técnico: "dado de cliente com nome, endereço, CPF'=PII — classificação confidential.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'dado de cliente com nome, endereço, CPF'=PII — classificação confidential....

7. Cenário corporativo (Data Types & Classifications): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.3), um analista avalia o seguinte requisito técnico: 'Classificação determina QUAL proteção cada dado recebe'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Classificação determina QUAL proteção cada dado recebe...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Data Types & Classifications): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.3), um analista avalia o seguinte requisito técnico: 'PHI = saúde; PCI-DSS = cartão; PII = dados pessoais'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: PHI = saúde; PCI-DSS = cartão; PII = dados pessoais...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Data Types & Classifications): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.3), um analista avalia o seguinte requisito técnico: 'least restrictive classification'=public; 'most restrictive'=restricted'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'least restrictive classification'=public; 'most restrictive'=restricted...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Data Types & Classifications): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.3), um analista avalia o seguinte requisito técnico: 'dado de cliente com nome, endereço, CPF'=PII — classificação confidential.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'dado de cliente com nome, endereço, CPF'=PII — classificação confidential....
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — O provedor de nuvem.

✓ **Por que está certa:** No modelo de responsabilidade compartilhada da computação em nuvem, a segurança física do datacenter — incluindo controle de acesso às instalações, vigilância por vídeo, energia redundante, climatização, prevenção e combate a incêndios, e proteção contra desastres naturais — é responsabilidade exclusiva do provedor de nuvem. A CompTIA Security+ SY0-701 enfatiza que o provedor é sempre responsável pela 'segurança DA nuvem' (a infraestrutura subjacente), enquanto o cliente é responsável pela 'segurança NA nuvem' (seus dados, configurações, identidades e aplicações). O cliente não tem acesso físico ao datacenter e, portanto, não pode implementar controles físicos; a responsabilidade é intransferível e não compartilhada nesse aspecto específico.

✗ **Por que as outras estão erradas:**

- *O cliente:* O cliente é responsável pela segurança NA nuvem, ou seja, por seus dados, configurações de acesso, criptografia de suas informações, gestão de identidades e patches em suas instâncias. Contudo, ele não possui acesso físico ao datacenter do provedor, não pode instalar fechaduras, câmeras ou sistemas de supressão de incêndio. Atribuir a segurança física ao cliente violaria o modelo de responsabilidade compartilhada, pois este não detém o controle do ambiente físico. A questão pergunta especificamente sobre a segurança FÍSICA do datacenter, que é domínio exclusivo do provedor.
- *Os dois igualmente:* A responsabilidade compartilhada não é dividida igualmente em todos os aspectos. Ela é segmentada por camadas: o provedor cuida da segurança física, da infraestrutura de virtualização e da rede subjacente; o cliente cuida da segurança de seus dados, aplicações e identidades. A segurança física do datacenter é uma camada que o cliente não pode operar nem auditar diretamente, logo não há compartilhamento igualitário. Dizer que ambos são igualmente responsáveis pela segurança física é tecnicamente incorreto e contraria o modelo definido pela CompTIA e pelos principais provedores de nuvem (AWS, Azure, GCP).
- *Um auditor externo:* Um auditor externo realiza avaliações independentes de conformidade, como certificações SOC 2, ISO 27001 ou PCI DSS, mas não executa a segurança física do datacenter. Ele verifica se os controles implementados pelo provedor estão adequados, porém não é responsável por operá-los. A auditoria é uma função de verificação, não de operação. Portanto, atribuir a segurança física a um auditor externo confunde o papel de fiscalização com o de execução, o que é um erro conceitual grave no contexto do modelo de responsabilidade compartilhada.

2) A — DLP (Data Loss Prevention).

✓ **Por que está certa:** DLP (Data Loss Prevention) é um conjunto de tecnologias e políticas que visam impedir a exfiltração de dados confidenciais, monitorando e controlando transferências de informações sensíveis. No CompTIA Security+ (SY0-701), o DLP é apresentado como um controle que pode bloquear o envio de dados para fora da organização, seja por e-mail, web, USB ou outros canais. O enunciado descreve exatamente um controle que impede um funcionário de enviar uma planilha confidencial para fora da empresa, o que é a função primária do DLP.

✗ **Por que as outras estão erradas:**

- *SSO:* SSO (Single Sign-On) é um mecanismo de autenticação que permite ao usuário acessar múltiplos sistemas com uma única credencial. Ele não controla a transferência de dados ou impede a exfiltração de informações. Portanto, não se aplica ao cenário descrito.
- *MFA:* MFA (Multi-Factor Authentication) é um método de autenticação que exige dois ou mais fatores de verificação para conceder acesso. Ele fortalece a autenticação, mas não impede que um

usuário autorizado envie dados confidenciais para fora. Não é um controle de prevenção de perda de dados. Logo, não é a resposta correta.

- **VPN:** VPN (Virtual Private Network) é uma tecnologia que cria um túnel criptografado para comunicação segura, mas não tem a função de inspecionar ou bloquear a transferência de dados confidenciais. Ela protege a transmissão, mas não impede a exfiltração por um usuário autorizado. Portanto, não atende ao requisito do enunciado.

3) D — Implementar a solução correspondente: Classificação determina QUAL proteção cada dado recebe....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.3 (Data Types & Classifications): Classificação determina QUAL proteção cada dado recebe.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) D — Implementar a solução correspondente: PHI = saúde; PCI-DSS = cartão; PII = dados pessoais....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.3 (Data Types & Classifications): PHI = saúde; PCI-DSS = cartão; PII = dados pessoais.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: 'least restrictive classification'=public; 'most restrictive'=restricted....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.3 (Data Types & Classifications): 'least restrictive classification'=public; 'most restrictive'=restricted.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: 'dado de cliente com nome, endereço, CPF'=PII — classificação confidential.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.3 (Data Types & Classifications): 'dado de cliente com nome, endereço, CPF'=PII — classificação confidential..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: Classificação determina QUAL proteção cada dado recebe....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.3 (Data Types & Classifications): Classificação determina QUAL proteção cada dado recebe.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: PHI = saúde; PCI-DSS = cartão; PII = dados pessoais....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.3 (Data Types & Classifications): PHI = saúde; PCI-DSS = cartão; PII = dados pessoais.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: 'least restrictive classification'=public; 'most restrictive'=restricted....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.3 (Data Types & Classifications): 'least restrictive classification'=public; 'most restrictive'=restricted.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: 'dado de cliente com nome, endereço, CPF'=PII — classificação confidential.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.3 (Data Types & Classifications): 'dado de cliente com nome, endereço, CPF'=PII — classificação confidential..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.